

HOW TO BUILD A CYBERSECURITY INCIDENT RESPONSE PROGRAM

A practical guide to preparation, detection, analysis, containment, recovery, and improvement

Alberto (Al) Leiva

Version 1.0 - July 2026

Table of contents

- Purpose and responsible use
- 1. Incident response fundamentals
- 2. Program governance and charter
- 3. Roles and responsibilities
- 4. Incident categories and severity
- 5. Preparation and readiness
- 6. Detection and reporting
- 7. Triage and initial analysis
- 8. Containment strategy
- 9. Eradication and remediation
- 10. Recovery and restoration
- 11. Evidence handling and forensics
- 12. Communications and notifications
- 13. Ransomware playbook
- 14. Cloud and identity incidents
- 15. Third-party and supply-chain incidents
- 16. AI-system incidents
- 17. Exercises and testing
- 18. Metrics and continual improvement
- 19. 30/60/90-day implementation plan
- 20. Production readiness checklist

Purpose and responsible use

This manual explains how to build, operate, test, and improve a cybersecurity incident response program. It is intended for lawful, authorized, and ethical defensive use.

Human safety, privacy, evidence integrity, and legal obligations must remain central throughout every investigation.

Severity model

Level	Example criteria	Target response
Critical	Safety risk, major outage, confirmed sensitive-data theft, active ransomware, widespread privileged compromise	Immediate executive activation and continuous response
High	Material business impact, limited sensitive-data exposure, persistent attacker, critical supplier compromise	Rapid activation and frequent executive updates
Medium	Contained compromise with limited impact or credible attempt requiring investigation	Same-business-day ownership and scheduled updates
Low	Suspicious event with low impact and no confirmed compromise	Routine queue with documented disposition

1. Incident response fundamentals

Incident response is an organization-wide capability for preparing for, detecting, analyzing, containing, eradicating, recovering from, and learning from cybersecurity incidents.

NIST SP 800-61 Revision 3 integrates incident response throughout cybersecurity risk management and aligns the capability with NIST Cybersecurity Framework 2.0.

2. Program governance and charter

Define the program mission, authority, scope, executive sponsor, service hours, escalation authority, decision rights, legal boundaries, and reporting expectations.

The charter should identify who may isolate systems, disable accounts, preserve evidence, engage outside counsel, contact law enforcement, and communicate externally.

3. Roles and responsibilities

Create a cross-functional team that includes security operations, IT, cloud, identity, legal, privacy, human resources, communications, business continuity, physical security, and executive leadership.

Use a RACI matrix so every critical task has one accountable owner and clear backup coverage.

4. Incident categories and severity

Define categories such as malware, ransomware, identity compromise, data exposure, cloud misuse, insider activity, denial of service, application compromise, supplier incident, and AI-system incident.

Severity should consider business impact, data sensitivity, safety, scope, persistence, regulatory exposure, operational disruption, and attacker capability.

Practical controls

- Document decisions and ownership.
- Preserve evidence before destructive changes.
- Apply least privilege and approval for high-impact actions.
- Maintain a normalized incident timeline.

5. Preparation and readiness

Maintain accurate inventories, hardened systems, protected backups, centralized logging, synchronized time, tested contacts, current diagrams, emergency access, and documented playbooks.

Prepare secure out-of-band communication methods in case normal email or collaboration tools are compromised.

6. Detection and reporting

Create multiple reporting channels for employees, customers, suppliers, automated security tools, and external researchers.

Define the minimum information required in an incident report: reporter, time, affected assets, observed behavior, evidence location, business impact, and actions already taken.

Core records

Record	Purpose
Incident ticket	Authoritative chronology, ownership, decisions, actions, and status
Evidence log	Source, collection method, hash, storage, access, and transfers

Decision log	Major containment, notification, recovery, and risk-acceptance decisions
Timeline	Normalized sequence of attacker and defender activity
After-action report	Root causes, impact, lessons, corrective actions, and owners

Practical controls

- Document decisions and ownership.
- Preserve evidence before destructive changes.
- Apply least privilege and approval for high-impact actions.
- Maintain a normalized incident timeline.

7. Triage and initial analysis

Validate whether the event is an incident, determine scope and urgency, identify affected identities and systems, preserve volatile evidence, and assign an incident commander.

Avoid premature conclusions. Record confirmed facts, working hypotheses, unknowns, and confidence levels separately.

Practical controls

- Document decisions and ownership.
- Preserve evidence before destructive changes.
- Apply least privilege and approval for high-impact actions.
- Maintain a normalized incident timeline.

8. Containment strategy

Containment should reduce harm while preserving evidence and avoiding unnecessary business disruption.

Options include disabling accounts, revoking tokens, isolating endpoints, blocking indicators, restricting network paths, suspending integrations, rotating credentials, and taking vulnerable services offline.

Practical controls

- Document decisions and ownership.
- Preserve evidence before destructive changes.
- Apply least privilege and approval for high-impact actions.
- Maintain a normalized incident timeline.

9. Eradication and remediation

Remove malicious artifacts, close persistence mechanisms, patch exploited weaknesses, correct insecure configurations, rebuild compromised systems when confidence is low, and invalidate stolen credentials.

Do not declare eradication complete until the team has tested for alternate persistence and related compromise.

Practical controls

- Document decisions and ownership.
- Preserve evidence before destructive changes.
- Apply least privilege and approval for high-impact actions.
- Maintain a normalized incident timeline.

10. Recovery and restoration

Restore services in a controlled sequence, validate integrity, increase monitoring, confirm business acceptance, and maintain a rollback plan.

Recovery criteria should be measurable and approved by technical and business owners.

Sample RACI

Activity	Accountable	Responsible	Consulted
Declare critical incident	Executive incident lead	Incident commander	Legal, business owner
Isolate endpoint	Security operations lead	SOC/EDR team	IT operations
Notify regulator	Legal/privacy lead	Legal/privacy team	Executive sponsor
Restore service	Business service owner	IT/cloud team	Security, continuity

Practical controls

- Document decisions and ownership.
- Preserve evidence before destructive changes.
- Apply least privilege and approval for high-impact actions.
- Maintain a normalized incident timeline.

11. Evidence handling and forensics

Preserve evidence in a manner appropriate to legal, regulatory, insurance, and internal requirements. Document collection time, collector, source, method, hash values when appropriate, transfers, storage, and access.

Use trained personnel and approved tools. Do not alter original evidence unnecessarily.

Practical controls

- Document decisions and ownership.
- Preserve evidence before destructive changes.
- Apply least privilege and approval for high-impact actions.
- Maintain a normalized incident timeline.

12. Communications and notifications

Create internal, executive, customer, regulatory, law-enforcement, insurer, and media communication plans before an incident occurs.

Use verified facts, protect privileged information, avoid speculation, coordinate timing, and maintain a decision log for notifications.

Practical controls

- Document decisions and ownership.
- Preserve evidence before destructive changes.
- Apply least privilege and approval for high-impact actions.
- Maintain a normalized incident timeline.

13. Ransomware playbook

Priorities include life and safety, containment, identity protection, preservation of evidence, restoration from trusted backups, legal and regulatory coordination, and assessment of data theft.

Do not assume encryption is the only impact. Investigate credential theft, persistence, lateral movement, and exfiltration.

Practical controls

- Document decisions and ownership.
- Preserve evidence before destructive changes.
- Apply least privilege and approval for high-impact actions.
- Maintain a normalized incident timeline.

14. Cloud and identity incidents

Cloud incidents often involve stolen tokens, excessive permissions, exposed secrets, compromised automation, malicious OAuth applications, or altered logging.

Review identity provider logs, conditional access, privileged role activation, service principals, workload identities, cloud control-plane activity, and data-plane access.

Practical controls

- Document decisions and ownership.
- Preserve evidence before destructive changes.

- Apply least privilege and approval for high-impact actions.
- Maintain a normalized incident timeline.

15. Third-party and supply-chain incidents

Require suppliers to provide timely notification, scope, indicators, affected services, containment status, and evidence needed for customer assessment.

Maintain alternate contacts and continuity options for critical suppliers.

Practical controls

- Document decisions and ownership.
- Preserve evidence before destructive changes.
- Apply least privilege and approval for high-impact actions.
- Maintain a normalized incident timeline.

16. AI-system incidents

AI incidents can include prompt injection, sensitive data leakage, unsafe autonomous actions, model or retrieval poisoning, compromised agent tools, and abuse of non-human identities.

Contain affected agents, tools, data indexes, credentials, and model endpoints. Preserve prompts, tool-call metadata, configuration versions, and approval records while protecting privacy.

Practical controls

- Document decisions and ownership.
- Preserve evidence before destructive changes.
- Apply least privilege and approval for high-impact actions.
- Maintain a normalized incident timeline.

17. Exercises and testing

Use tabletop exercises, technical simulations, communication drills, backup restoration tests, and supplier exercises.

Every exercise should produce documented findings, owners, due dates, retest results, and changes to plans or controls.

Practical controls

- Document decisions and ownership.
- Preserve evidence before destructive changes.
- Apply least privilege and approval for high-impact actions.
- Maintain a normalized incident timeline.

18. Metrics and continual improvement

Measure readiness, detection time, analysis time, containment time, recovery time, recurrence, evidence quality, exercise completion, overdue actions, and stakeholder satisfaction.

Use metrics to improve capability rather than punish individuals for reporting incidents.

19. 30/60/90-day implementation plan

First 30 days: establish sponsorship, charter, contacts, severity model, reporting channel, top playbooks, and minimum logging requirements.

Days 31-60: define roles, evidence procedures, communication plans, supplier expectations, exercises, and technical containment capabilities.

Days 61-90: conduct a full tabletop, remediate gaps, automate evidence and metrics, integrate lessons learned, and obtain executive approval.

20. Production readiness checklist

Use the checklist below before declaring the program operational.

Readiness checklist

- ☐ Executive sponsor assigned
- ☐ Program charter approved
- ☐ 24/7 contact and escalation paths tested
- ☐ Severity matrix approved
- ☐ Top incident playbooks documented
- ☐ Secure out-of-band communications available
- ☐ Logging and time synchronization verified
- ☐ Evidence handling procedure approved
- ☐ Legal, privacy, insurance, and communications contacts confirmed
- ☐ Containment authority documented
- ☐ Backup restoration tested
- ☐ Cloud and identity emergency procedures tested
- ☐ Supplier notification requirements established
- ☐ AI incident procedures included where applicable

- ☐ Tabletop exercise completed
- ☐ Corrective actions tracked to closure
- ☐ Metrics and executive reporting established
- ☐ Annual review date scheduled

Official references

[NIST SP 800-61 Rev. 3 - Incident Response Recommendations and Considerations](#)

[NIST Cybersecurity Framework 2.0](#)

[CISA Cybersecurity Incident and Vulnerability Response Playbooks](#)

[Microsoft incident response planning](#)

[Microsoft cloud security benchmark - Incident Response](#)

License

Copyright © 2026 Alberto (Al) Leiva. Licensed under CC BY-NC-SA 4.0.